# Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-21 09:00 WIB

## Top 5 Highlights

- Oracle October 2026 Critical Patch Update Addresses 1209 CVEs
- KVM escape exposes broader attack surface in Linux networking
- PHP warns admins of two critical flaws, emergency patches coming tomorrow
- Threat Brief: Active Exploitation of PAN-OS CVE-2026-0257 (Updated October 20)
- Siemens Software Center flaw exploited in ClickFix DLL-sideloading attack

# Threat Intelligence (10)

## 01. Malicious Rank Math PRO version distributed in supply chain attack

Users downloaded malicious versions of Rank Math PRO last week, after the WordPress SEO plugin was compromised in a supply chain attack.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.scworld.com/brief/malicious-rank-math-pro-version-distributed-in-supply-chain-attack

## 02. AOMEI Backupper servers hijacked for minutes at a time to push backdoor

An unknown number of AOMEI Backupper users had their computers infected with a backdoor through an unusually stealthy supply chain attack, security researchers discovered. Between April and July 2026, attackers repeatedly altered configuration files on AOMEI’s own servers for just five to ten minutes at a time, then restored the originals. The tampered file…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.helpnetsecurity.com/2026/10/20/aomei-backupper-compromised-supply-chain/

## 03. AOMEI Backupper Compromised in Short-Burst Supply Chain Campaign

Across multiple short compromise windows, users were served a downloader for the ShinyRoad modular backdoor framework. The post AOMEI Backupper Compromised in Short-Burst Supply Chain Campaign appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.securityweek.com/aomei-backupper-compromised-in-short-burst-supply-chain-campaign/

## 04. Hacker gets 8 years for stealing $3.3 million from taxpayers

A Nigerian national was sentenced to eight years in prison for his involvement in a series of spearphishing attacks targeting US tax preparation businesses since 2019. […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.bleepingcomputer.com/news/security/hacker-gets-8-years-for-stealing-33-million-from-taxpayers/

## 05. OVHcloud CLI releases backdoored on GitHub to steal developer secrets

French cloud and hosting provider OVHcloud is warning users that attackers compromised its open-source command-line interface (CLI) tool to distribute information-stealing malware. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/ovhcloud-cli-releases-backdoored-on-github-to-steal-developer-secrets/

## 06. Russian APT28 Breaches NATO Naval Shipbuilder in NATO Country, Deploys New Reflective Loader

The Russia-linked state-sponsored threat actor tracked as APT28 (aka BlueDelta, Fancy Bear, and Forest Blizzard) has been attributed to attacks targeting two member states of the North Atlantic Treaty Organization (NATO). The Symantec Threat Hunter Team, which is tracking the activity cluster under the moniker Swallowtail, involved the use of a backdoor cal...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/russian-apt28-breaches-nato-naval.html

## 07. [+24h Old] Hackers Hijack Five OVHcloud CLI Releases to Distribute Secret-Stealing Malware

An attacker used a contributor's GitHub account to replace the download archives on five existing releases of OVHcloud's command-line tool on Monday, October 19. The account had been hijacked, and the new files were a build designed to steal secrets stored on the disk of any machine that runs it, the cloud provider says. They were live on GitHub for up to 9...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/hackers-hijack-five-ovhcloud-cli.html

## 08. [+24h Old] Hackers Use New ROMULUS ClickFix Platform to Deliver LegionLoader and Other Malware

Cybersecurity researchers have disclosed details of a ClickFix delivery platform called ROMULUS that's being used to distribute malware such as Legion Loader. According to Forescout Research - Vedere Labs, ROMULUS is akin to a malware delivery service that

employs ClickFix-style lures on bogus landing pages to trick unsuspecting users into running malicious…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/romulus-clickfix-platform-tricks-users.html

### 09. [+24h Old] ISC Stormcast For Tuesday, October 20th, 2026 https://isc.sans.edu/podcastdetail/10142, (Tue, Oct 20th)

ISC Stormcast For Tuesday, October 20th, 2026 https://isc.sans.edu/podcastdetail/10142, (Tue, Oct 20th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://isc.sans.edu/diary/rss/33436

### 10. [+24h Old] WordPress SEO plugin Rank Math compromised to backdoor websites

Some downloads of the Rank Math PRO WordPress plugin from the vendor's official website carried malware that planted hidden backdoors in a supply-chain attack last week. […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/wordpress-seo-plugin-rank-math-compromised-to-backdoor-websites/

## Latest Vulnerabilities (10)

### 01. Oracle October 2026 Critical Patch Update Addresses 1209 CVEs

Oracle addresses 1209 CVEs in its final quarterly update of 2026 with 1295 patches, including 112 critical updates. Key Takeaways The October 2026 Critical Patch Update (CPU) contains fixes for 1209 unique CVEs in 1295 security updates 112 issues (8.6% of all patches) were assigned a critical severity rating Oracle Fusion Middleware received the highest num…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.tenable.com/blog/oracle-october-2026-critical-patch-update-addresses-1209-cves

## 02. KVM escape exposes broader attack surface in Linux networking

Security researchers have found a critical flaw in the Linux kernel’s networking stack that can let attackers escape a KVM virtual machine and execute code on the host system. The weakness could also potentially let attackers compromise systems running other Linux-based virtualization and sandbox platforms. Tracked as CVE-2026-99999 and dubbed PwnEscape , t…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4237999/kvm-escape-exposes-broader-attack-surface-in-linux-networking.html

## 03. PHP warns admins of two critical flaws, emergency patches coming tomorrow

The PHP security team is warning administrators to prepare for emergency security updates tomorrow to address two critical vulnerabilities, as information about the flaws has reportedly leaked ahead of their scheduled disclosure. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/php-warns-admins-of-two-critical-flaws-emergency-patches-coming-tomorrow/

## 04. Threat Brief: Active Exploitation of PAN-OS CVE-2026-0257 (Updated October 20)

Ransomware operators including Spikey Scorpius (aka Qilin) and Tarnished Scorpius (aka Inc) are exploiting PAN-OS vulnerability CVE-2026-0257. The post Threat Brief: Active Exploitation of PAN-OS CVE-2026-0257 (Updated October 20) appeared first on Unit 42 .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://unit42.paloaltonetworks.com/active-exploitation-of-pan-os-cve-2026-0257/

## 05. Siemens Software Center flaw exploited in ClickFix DLL-sideloading attack

Malware lets attackers gain the Siemens app with full privileges into industrial enterprises.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/news/siemens-software-center-flaw-exploited-in-clickfix-dll-sideloading-attack

## 06. The Real Jump Scare Isn’t the Attacker; It’s The Vulnerabilities You’re Focusing On

Key Takeaways Teams are remediating more than ever, but exposure from the vulnerabilities that matter is still rising faster than they can keep up with. Mean time to exploitation is about -7 days. Mean time to remediate sits around +30 days. Qualys research: closures rose from 73M (2022) to 473M (2025) - 6× - while […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://blog.qualys.com/qualys-insights/2026/10/20/remediation-paradox-cybersecurity-awareness-month

## 07. [0day-rubbish] TRENDnet TV-IP302PI firmware 1.02.38 authenticated NTP server-address OS command injection to root command execution via a shell-form system() call (7.2 High, PR:H)

Posted by disclosure via Fulldisclosure on Oct 20 0day Rubbish Research Team is publicly disclosing a vulnerability in TRENDnet TV-IP302PI firmware 1.02.38, the closed-source IP surveillance camera from TRENDnet (United States). The camera's application daemon is shipped at /hunt/hunt_server: an ARM 32-bit EABI5 version 5TE soft-float binary, dynamically li…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://seclists.org/fulldisclosure/2026/Oct/34

## 08. [0day-rubbish] Royal Render 9.1.26b: default-unauthenticated job submission on rrServer TCP 7773 reaches worker-side shell execution as the worker identity, measured root (8.1 High)

Posted by disclosure via Fulldisclosure on Oct 20 0day Rubbish Research Team is publicly disclosing a vulnerability in Royal Render 9.1.26b, the closed-source render-farm job manager for VFX and animation studios from Binary Alchemy (proprietor Holger Schoenberger) of Ludwigsburg, Germany. Royal Render is a different product from the Royal Server gateway so…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://seclists.org/fulldisclosure/2026/Oct/33

### 09. [0day-rubbish] ProSoft Technology RLX-IFH24E v2.2.44 unsigned firmware upgrade package to root command execution and full account-database overwrite (7.2)

Posted by disclosure via Fulldisclosure on Oct 20 0day Rubbish Research Team is publicly disclosing a vulnerability in the ProSoft RLX-IFH24E, version v2.2.44, the industrial wireless radio from ProSoft Technology, Inc. (United States). The appliance is a closed-source embedded device and an OEM build of the MicroHard Systems IPx21 platform on the MHX-910 b…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://seclists.org/fulldisclosure/2026/Oct/32

### 10. [0day-rubbish] Parasoft Continuous Testing Platform 10.7.5-SNAPSHOT anonymous deserialization in the database restore path to JSP command execution as uid=1000 (9.8)

Posted by disclosure via Fulldisclosure on Oct 20 0day Rubbish Research Team is publicly disclosing a vulnerability in Parasoft Continuous Testing Platform 10.7.5-SNAPSHOT, the closed-source commercial continuous-testing, service-virtualisation and environment-management product from Parasoft, a United States software-testing vendor headquartered in Monrovi…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://seclists.org/fulldisclosure/2026/Oct/31

## Data Breach & Cybercrime (10)

### 01. Zeabur shutting down after second security breach in two months

Development platform Zeabur has disclosed details of a cybersecurity incident in which an attacker used leaked internal credentials stored in plaintext to compromise its infrastructure and steal over 3.2 million environment variable records and information for 321,810 accounts. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/zeabur-shutting-down-after-second-security-breach-in-two-months/

### 02. Ex-OpenAI Engineer Detained After Planting Secret Recorder at HQ

The perp, who has Saudi ties, was arrested for allegedly bugging an OpenAI conference room, highlighting a preventable insider threat vector.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/insider-threats/ex-openai-engineer-secret-recorder-saudi-ties

## 03. Palo Alto's firewall OS has been under attack from multiple ransomware groups since June

Unit 42 investigates network compromises across numerous industries

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.theregister.com/cyber-crime/2026/10/20/palo-altos-firewall-os-has-been-under-attack-from-multiple-ransomware-groups-since-june/5304226

## 04. Chrome flags malicious commands that scammers pass off as fixes

Google is updating Chrome’s Enhanced Protection mode to detect scam websites and warn users when a page tricks them into copying a malicious command. The company introduced Enhanced Protection for Chrome’s Safe Browsing feature in 2020 to address online scams and social engineering. Google says further updates have made its users ten times safer from phishi…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/10/20/google-chrome-enhanced-protection-updates/

## 05. The Risk of AI-Powered Antidetect Browsers in Online Fraud and Influence Operations

Key Findings Introduction Antidetect browsers conceal their users’ digital identities, enabling a single operator or small team to simultaneously run thousands of isolated accounts across multiple platforms such as Facebook, Instagram, TikTok, YouTube, Twitter/X, Discord, LinkedIn, Reddit, and many more, without triggering the detection systems employed by…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://research.checkpoint.com/2026/the-risk-of-ai-powered-antidetect-browsers-in-online-fraud-and-influence-operations/

## 06. Hackers Use Autonomous AI Agents to Breach Company Websites, Target Over 1,200 Sites

A Chinese-speaking criminal pointed autonomous AI agents at company websites and let them break in with almost no help, and a security researcher watched it happen because the operators left their control panels open on the internet. The agents tried more than 1,200 sites and reached websites belonging to more than 100 companies, including farm-equipment ma…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/hackers-use-autonomous-ai-agents-to.html

## 07. 'Password1' and a forgotten test account land Welsh outfits in hot water

ICO reprimands Ogi Networks and Data Cymru after ransomware breach exposes info of 3,300 people, mostly children

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.theregister.com/cyber-crime/2026/10/20/password1-and-a-forgotten-test-account-land-welsh-outfits-in-hot-water/5304139

## 08. Ex-OpenAI Worker Accused of Bugging Conference Room Planned to Fly to Saudi Arabia, Prosecutors Say

Abdulrahman Alfozan’s wife and young son also left the country the day after the 35-year-old Saudi national’s arrest. The post Ex-OpenAI Worker Accused of Bugging Conference Room Planned to Fly to Saudi Arabia, Prosecutors Say appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/ex-openai-worker-accused-of-bugging-conference-room-planned-to-fly-to-saudi-arabia-prosecutors-say/

## 09. [+24h Old] 970,000 Medi-Cal Members Affected by Paradigm Healthcare Data Breach

Paradigm Healthcare Services detected an intrusion in October 2025, but it took nearly a year to start notifying affected individuals. The post 970,000 Medi-Cal Members Affected by Paradigm Healthcare Data Breach appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/970000-medi-cal-members-affected-by-paradigm-healthcare-data-breach/

## 10. [+24h Old] Nikkei discloses third data breach in a month, 1.8M records exposed

Nikkei Inc. disclosed a new data breach, the third in about a month, that exposed 1.83 million personal information records. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/nikkei-discloses-third-data-breach-in-a-month-18m-records-exposed/